

NAME : ROHAN JASH

STREAM : CSE AIML

SEMESTER : 5TH

BATCH : 2023-27

The Human Firewall Audit

FinSecure Pvt Ltd — Social Engineering Simulation & Defense Plan

Objective: Ethically simulate a multi-vector SE attack against FinSecure and design defenses.

Deliverables: Attack write-up, OSINT recon, multi-vector attack plan, awareness materials, red-flag checklist, defense strategy.

Ethics: All data fictional or from public sources; no real attacks.

Target Profile — FinSecure Pvt Ltd

- Mid-sized fintech company (50 employees) headquartered in Bengaluru.
- Core services: payment processing, personal finance app, API integration for SMEs.
- Key roles: CTO, Head of Ops, DevOps engineers, Customer Support, Finance team.
- Tech stack (assumed from public postings): AWS, Node.js, PostgreSQL, Slack, Office 365.

OSINT Recon — Key Findings

- LinkedIn: several engineers and finance leads with job titles and location.
- Company website: public blog, product docs, careers page listing tech.
- Job boards & GitHub: evidence of Node.js and cloud keywords.
- Social media: employee posts reveal internal tool names and team structures.
- Publicly available email format: `firstname.lastname@finsecure.com` (assumed).

Threat Model & Attacker Goal

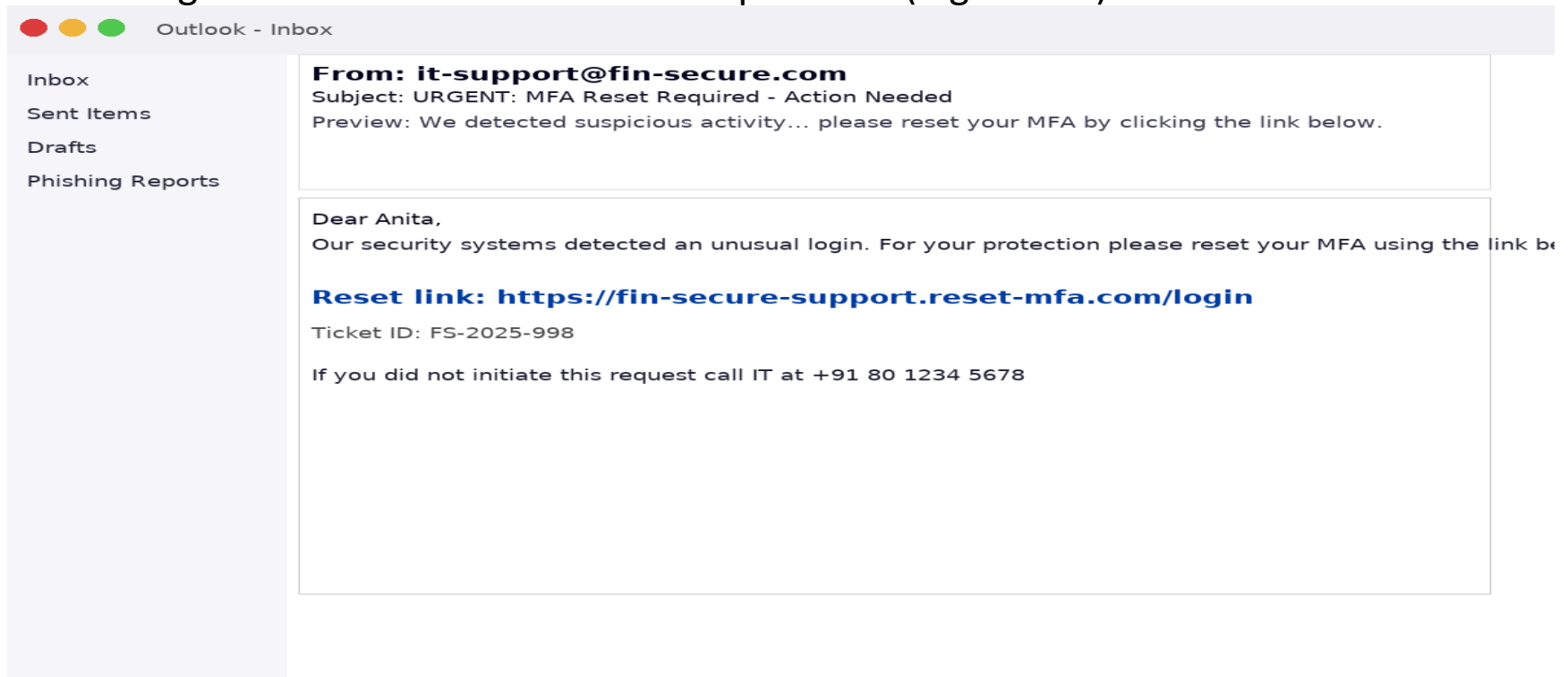
- Attacker type: targeted opportunistic social engineer.
- Primary goal: Obtain valid VPN credentials or MFA bypass to access internal repo containing PII.
- Secondary goals: Install persistence via privileged user or exfiltrate customer data.

Multi-Vector Attack Scenario

- Vectors combined: Phishing (spear-phish email) + Phone impersonation (vishing).
- Pretext: IT helpdesk requesting urgent MFA reset due to 'scheduled maintenance'.
- Execution window: 2-3 days after reconnaissance and crafted pretext messages.

Phishing Email — Execution Plan

- Craft email from spoofed internal address or lookalike domain (e.g., 'fin-secure.com').
- Email content: Urgent MFA reset link with convincing header and support ticket ref.
- Landing page: Fake internal SSO page capturing credentials; includes plausible SSL-like details.
- Target selection: Finance and DevOps teams (high value).



Vishing Follow-Up — Execution Plan

- Caller ID spoofing to match internal IT number.
- Caller script: 'This is IT support — we detected suspicious login; need to verify your code'.
- Use urgency to bypass verification and request temporary codes or to prompt clicking link.
- Combine with phishing to increase legitimacy (reference ticket ID from email).

Internal Communication - Call Logs

Incoming Call (mock):

Caller ID: +91 80 1234 5678 (Displayed as 'IT Support')

Time: 2025-10-12 10:23 AM

Transcript:

Caller: Hello Anita, this is IT. We saw unusual activity on your account.

Caller: I need the 6-digit MFA code to verify your session. Ticket FS-2025-998.

User: I don't have the code yet.

Caller: Please read the code now, it's urgent or we'll lock your account.

Optional Additional Vector — USB Drop

- Drop branded USB with README 'FinSecure onboarding docs' near office cafe.
- USB contains a macro-enabled doc that prompts enabling macros to 'view legal contract'.
- Goal: get local machine foothold for lateral movement.

Awareness Campaign — Poster Concept

Poster headline: "Pause — Verify Before You Click"

Visuals: A large image of an email with a red flag icon, phone handset with warning bubble.

Message: "IT will never ask for your password or OTP. Verify via the internal ticketing portal."

Call to action: "Report suspicious emails to infosec@finsecure.com — Use the 'Report Phish' button in Outlook."

PAUSE — VERIFY BEFORE YOU CLICK

IT WILL NEVER ASK FOR YOUR PASSWORD OR OTP

Red Flags:

- Urgency and pressure to act immediately
- Unexpected requests for OTPs or passwords
- Sender domain doesn't match official domain
- Links that preview to different URLs

If suspicious: Use 'Report Phish' in Outlook or email infosec@finsecure.com

Reward program for reporting: Win recognition and gift vouchers.

Red Flag Checklist

- Behavioral red flags: Unexpected urgency, canonical tone mismatch, mismatched salutations, unusual requests for codes.
- Technical red flags: Sender domain mismatch, link URL preview differs, attachments with macros, unusual header SPF/DKIM failures.
- Phone red flags: Caller refuses to allow call-back, requests OTPs, uses pressure tactics.

Defense Strategy — Technical Controls

- Enforce MFA for all remote access and admin accounts (FIDO2 where possible).
- Deploy advanced email filtering with DMARC/DKIM/SPF enforcement and anti-phishing rules.
- Implement SSO with conditional access policies (device compliance + geographic rules).
- Endpoint protection & EDR with USB device control and macro-blocking policies.

Defense Strategy — Awareness Plan

- Regular simulated phishing campaigns and targeted follow-up coaching.
- Mandatory annual security training + quarterly microlearning modules.
- Clear escalation path: 'Report Phish' button + quick response team within 1 business hour.
- Reward program for reporting legitimate threats (gamification + recognition).

Detection & Incident Response

- Monitor authentication anomalies: spike in failed MFA, new IPs, impossible travel.
- Hunt for credential reuse and suspicious session tokens.
- Pre-built IR playbook: credential compromise — contain, revoke tokens, force password resets, forensic imaging.
- Tabletop exercises quarterly including SE scenarios.

References & Ethics

- Scenario is fictional; only public OSINT sources used.
- Suggested reading: notable SE incidents (e.g., Twitter 2020, RSA 2011) — cite during full report.
- Keep all simulations within legal/ethical boundaries and obtain stakeholder sign-off for real exercises.

Appendix — Screenshots & Evidence (Placeholders)

- Include screenshots of OSINT findings (LinkedIn profiles, job posts) — redact personal data.
- Attach example phishing email mockups and fake landing page screenshot (for training only).
- Include phishing simulation metrics and post-training improvement graphs.

https://github.com/finsecure

FinSecure / internal-tools (public mirror - redacted)

README (excerpt):

This repo contains helper scripts for deployment. Tech: Node.js, AWS CLI

Files:

- deploy.sh 57 lines
- README.md contains CI hints
- creds.example.json (REMOVED) -> note presence in history

https://www.linkedin.com/in/anita-rao-finsecure



Anita Rao

DevOps Engineer at FinSecure Pvt Ltd

Bengaluru, India | 5 connections

Recent posts:

- Pushing new CI/CD pipeline to production
- Sharing snippet: AWS Lambda + Node.js auth